

HW06 API Testing — Main Report

HW06 API Testing Report

Student: Nguyễn Chí Đức (23127172)
Repository: <https://github.com/Jiduckiess/HW06>
SUT deployment: <http://localhost:3000>
Date: 2026-08-29

1. Scope and API selection

API	Pool	Feature	Endpoint(s)	Precondition / test data
API 1	A	FR-02 — Login and account lockout	POST /api/login	Valid user, invalid-password attempts, locked account
API 2	B	FR-08 — Checkout	POST /api/checkout	Authenticated user; empty/valid cart variations
API 3	C	FR-14 — Category management (CRUD)	GET/POST /api/categories, PUT/DELETE /api/categories/:id	Admin and non-admin user tokens; existing category

The selected features are FR-02 from Pool A, FR-08 from Pool B, and FR-14 from Pool C. Group-level uniqueness must be confirmed by the student with their instructor/team if required.

2. Test design and AI generation

For each API, document a step-by-step AI conversation—not one broad prompt—and link to its audit entries.

API 1 — FR-02 Login and account lockout (POST /api/login)

- Specification source: Authentication §1.2.
- Domain partitions: email (valid, missing, empty, malformed, boundary length, SQLi payload); password (valid, missing, empty, incorrect, boundary length, injection payload).
- State transitions: successful login; repeated failed logins → account lockout; attempt while locked; unlock/reset behavior based on observed SUT requirements.
- Security requirements: authentication bypass, credential stuffing/lockout behavior, injection, token disclosure.
- Schema assertions: successful response includes JWT token and user exactly as specified; error responses are consistent and do not disclose passwords.
- AI-generated test count: 35 (target met; five student extensions added)

- Test-case artifact: ../test-cases/api-1.md

API 2 — FR-08 Checkout (POST /api/checkout)

- Specification source: Cart & Orders §4.3.
- Domain partitions: total_amount (positive, zero, negative, decimal, nonnumeric, missing, manipulated); shipping_address (valid, empty, missing, long, special characters); authorization (valid/missing/malformed/expired token).
- State transitions: cart state before/after checkout; repeated checkout/idempotency; order creation failure behavior.
- Security: ownership and total-price tampering; unauthorized checkout; injection payloads.
- Schema assertions: order/confirmation response must match observed/specification contract.
- AI-generated test count: 35 (target met; five student extensions added and human audit completed)
- Test-case artifact: ../test-cases/api-2.md

API 3 — FR-14 Category management (CRUD)

- Endpoints: GET /api/categories, POST /api/categories, PUT /api/categories/:id, DELETE /api/categories/:id.
- Specification source: Products & Categories §3.4. Validate authorization behavior against the running SUT because the short specification does not explicitly state role requirements for category CRUD.
- Domain partitions: category name (valid, missing, empty, whitespace, duplicate, boundary length, Unicode, injection); id (existing, absent, zero, negative, nonnumeric, injection).
- State transitions: create → read → update → delete; update/delete non-existent or already-deleted category; preserve referential integrity if categories are in use.
- Security: unauthenticated/non-admin mutation, IDOR, mass-assignment and injection attempts.
- Schema assertions: category list/object and all success/error response structures.
- AI-generated test count: 35 (target met; five student extensions added)
- Test-case artifact: ../test-cases/api-3.md

3. Human audit

Each AI case is labelled VALID, INVALID, or INCOMPLETE in the test-case artifacts. Explain material corrections here.

API	AI cases reviewed	Valid	Invalid	Incomplete	Corrections made
API 1	35	27	0	8	Corrected enumeration and lockout cases against FR-02; added final oracles/characterization corrections for the remaining eight incomplete cases in api-1.md.
API 2	35	17	6	12	Corrected client-total oracles against FR-08, promoted explicit cart-clear/ownership cases, and documented final execution rules for unsupported address/schema/transport policies.
API 3	35	26	0	9	Corrected public category-read authorization against FR-12, confirmed PUT from the API specification, and added five FR-14-only extensions.

4. Student extensions

Add at least five AI-missed cases per API, especially security or state-transition cases.

ID	API	Added case	Why AI missed it	Evidence/result
A1-036-A1-040	API 1	Request parsing, concurrent lockout, counter reset, expiry, and account/IP isolation	AI prompt focused on single-request partitions and did not enumerate malformed transport, concurrent state, timer-boundary, or lock-keying scenarios	Defined in api-1.md; results are recorded in the FR-02 report.
B1-036-B1-040	API 2	Address/amount type confusion, corrupt-cart trust boundary, rollback, and duplicate JSON keys	AI focused on ordinary field partitions and missed parser ambiguity, cart integrity, and failed-transaction state preservation	Defined and audited in api-2.md; results are recorded in the FR-08 report.
C1-036-C1-040	API 3	Unicode blank names, update type validation, update mass assignment, stale IDs, and escaped valid names	AI did not propagate create-only partitions to update or explore state-derived IDs and legitimate JSON escaping across the full lifecycle	Defined and audited in api-3.md; results are recorded in the FR-14 report.

5. Execution

- Toolchain: Postman + Newman
- Required header: X-Student-Id: 23127172 applied by collection pre-request script.
- Command: `newman run postman/HW06_API_Testing.postman_collection.json -e postman/HW06.local.postman_environment.json -r cli,htmlextra --reporter-htmlextra-export evidence/newman/newman-report.html`
- Newman CLI log: `../evidence/terminal/FR-02.txt`
- Newman HTML report: `../evidence/newman/fr02-newman-report.html`
- Postman Run Results export: `../postman/results/fr-02/HW06 API Testing — 23127172.postman_test_run.json`

- FR-08 Newman HTML report: ../evidence/newman/fr08-newman-report.html
- FR-08 Postman Run Results export: ../postman/data/fr-08/HW06 API Testing — 23127172.postman_test_run.json
- FR-14 Newman HTML report: ../evidence/newman/fr14-newman-report.html
- FR-14 Postman Run Results export: ../postman/data/fr-14/HW06 API Testing — 23127172.postman_test_run.json
- Header console screenshots: console 1 and console 2.
- Excel test cases and summary: ../excel/HW06_API_Test_Cases_and_Summary.xlsx

API	Planned	Executed	Passed	Failed	Newman evidence
API 1	40	40	35	5	FR-02 execution report
API 2	40	40	30	10	FR-08 execution report — 103/114 assertions passed; 11 assertions failed
API 3	40	40	22	18	FR-14 execution report — 72/92 assertions passed; 20 assertions failed

6. Postman features used

Feature	How it was used	Evidence
Collection / folders	One collection, separated into FR-02, FR-08, and FR-14 folders; each folder has one data-driven request.	Collection export
Variables / environment	baseUrl and studentId are supplied through the selected HW06 Local environment; tokens and passwords stay out of the committed environment example.	Environment example
Pre-request script	Sets X-Student-Id, applies row-specific headers/body data, and writes request context to the Postman Console.	Console screenshots · console 2
Data-driven run	The Runner executes 40 JSON rows per selected API using fr02-data.json, fr08-data.json, and fr14-data.json.	Postman data
Runner / Newman	Runner verifies interactive execution; Newman executes the same collection/data in the CLI and in GitHub Actions.	Newman scripts · CI workflow

7. Bugs

Bug ID	Summary	Severity	GitHub issue	Screenshot	AI missed?
BUG-01	Login response exposes user .password	High	Issue #1	Newman log + Issue screenshot	No — schema assertion detected it
BUG-02	Checkout trusts client-supplied total_amount	Critical	Issue #2	FR-08 Newman evidence, B1-026/B1-027/B1-037	No — data-driven assertion detected it
BUG-03	Checkout accepts missing or null shipping address	High	Issue #3	FR-08 Newman evidence, B1-011/B1-036/B1-039	No — data-driven assertion detected it
BUG-04	text/plain JSON checkout input causes HTTP 500	Medium	Issue #4	FR-08 Newman evidence, B1-033	No — robustness assertion detected it
BUG-05	Category create/update accepts missing, blank, or non-string names	High	Issue #5	FR-14 Newman evidence, C1-007-C1-009/C1-013/C1-023-C1-024/C1-036-C1-037	No — data-driven assertion detected it
BUG-06	Normal user can create, update, and delete categories	Critical	Issue #6	FR-14 Newman evidence, C1-020/C1-028/C1-033	No — authorization assertion detected it
BUG-07	Category parser/content-type failures expose a stack trace or return HTTP 500	Medium	Issue #7	FR-14 Newman evidence, C1-017/C1-018	No — robustness assertion detected it

Issue evidence index: ../evidence/github-issues.md.

Only report reproducible, genuine bugs. Attach an issue screenshot for each bug.

8. CI/CD report

- Workflow: .github/workflows/api-tests.yml
- Initial failing run: fa69add / HW06 API tests #1 and manual run #2 failed because the workflow did not check out the eshop-sut submodule.
- Fix commit: 7bb12f3 — fix(ci): checkout SUT submodule.
- Historical run: HW06 API tests #3, triggered by push of commit 7bb12f3 on main, passed in 30 seconds. It used continue-on-error, so it proves submodule checkout only and is not claimed as an all-tests-pass baseline.
- Strict baseline: the workflow now applies the versioned SUT remediation patch, resets SUT state between suites, and removes continue-on-error. Local pre-push verification passed FR-02 (80 assertions), FR-08 (113 assertions), and FR-14 (91 assertions), with zero failures.
- Strict all-pass run: GitHub Actions #32505802850, commit 1e6e571, conclusion success. Screenshot: all-passed.png.
- Required intentional-failure run: GitHub Actions #32505900553, commit 1998d99, conclusion failure. It changed only A1-001's expected status from 200 to 201; GitHub Actions #32506035480, commit 473fd8f, restores the correct oracle and concludes success. Screenshot: one-failed.png.
- Security note: CI uses GitHub Actions Secrets for runtime credentials and does not publish raw Newman reports, because raw reports may contain passwords or JWTs.

9. AI-driven API test generator

- Design: ../generator/design.md
- Self-drawn/editable Mermaid diagram: generator/diagram.md
- Optional demo video: not supplied.

10. AI critique (200-300 words)

AI accelerated the breadth of this assignment, but it did not replace test analysis. Its first drafts generated many useful input partitions, yet several expected outcomes were too confident when the API specification did not define a business rule. For example, the first checkout cases assumed that malformed or missing `total_amount` must always be rejected. After review, the better requirement was that the server must never trust that client field: it may reject the request or safely recompute the total from the cart. Similarly, several `lockout`, `timing`, `content-type`, and `category-ID` cases had to be marked `INCOMPLETE` until the implementation or an approved requirement supplied a reliable oracle.

The real execution evidence was also essential. AI could propose password disclosure, client-controlled order totals, invalid address acceptance, missing role authorization, and parser-error handling as risks; Newman and Postman determined whether these risks were genuine defects. The original SUT runs exposed seven reproducible bugs, while the later CI baseline used a versioned remediation patch and strict assertions to demonstrate regression protection. These two contexts must not be confused: a green CI run after a fix does not erase the original defect evidence.

The main lesson is that human review supplies accountability and context. I had to decide which cases were valid, which were incomplete, what state setup was needed for checkout, how to isolate cart data, what evidence could be reported safely, and which screenshots/redactions were appropriate. AI was most useful as a structured assistant for exploring coverage gaps and drafting artifacts; the student remained responsible for requirements, execution, findings, and final claims.

Appendix A — AI Audit Report

See `ai-audit-report.md`.